Final Handover Package

The complete response to Amna's review, section by section. Every one of the 18 items from your handover doc is answered below with a clear status and a link to the delivered file.

PREPARED FOR
Amna, PhysioGuidance

PREPARED BY
Ghulam

DATE
2026-08-17

DEPLOYED COMMIT
`616a0341`

PHYSIOGUIDANCE
Riyadh · Saudi Arabia
me-central2 · GCP Cloud Run

How this folder is organised

Every folder maps to one section number in your review doc. Open the folder for that section to find the file(s) that answer it.

```
02-cicd-deployment/                  → §2  CI/CD & Deployment Independence
03-repository-verification/          → §3  Final Repository Verification
04-missing-deliverables/             → §4  Missing / Incomplete Deliverables
05-user-guides/                      → §5  User Guides (all six roles)
06-payment-gateways/                 → §6  Payment Gateway Production Config
07-nelc-final-evidence/              → §7  NELC Final Handover Evidence
08-pdpl-compliance/                  → §8  PDPL Technical Completion
09-security-hardening/               → §9  Security Hardening
10-monitoring-alerting/              → §10 Monitoring & Alerting
11-disaster-recovery/                → §11 Disaster Recovery & Backups
12-cost-optimization/                → §12 GCP Cost Optimization
13-budget-alert/                     → §13 Budget Alert
14-env-config-and-secrets/           → §14 Environment Config & Secrets
15-third-party-services/             → §15 Third-Party Services Ownership
16-documentation-consistency/        → §16 Documentation Consistency
17-final-production-verification/    → §17 Final Production Verification
18-ownership-confirmation/           → §18 Final Ownership Confirmation
```

Status vocabulary matches your doc: **Completed / Will Complete / Requires Client Action / Not Applicable**.

---

§2 — CI/CD & Deployment Independence

Your ask: No dependency on my personal machine; repository-driven deploys via GitHub Actions; all scripts committed; documented prerequisites, deployment sequence, credential auth, migrations, per-service deploy, rollback; demonstrable clean-machine deploy.

Status: Completed.

Delivered in 02-cicd-deployment/:

- `cicd-deployment.pdf` — full CI/CD documentation. Four GitHub Actions workflows (`deploy-backend.yml`, `deploy-frontend.yml`, `deploy-worker.yml`, `deploy-strapi.yml`) with `workflow_run` chaining. Workload Identity Federation replaces JSON keys (no long-lived credentials on any machine). Every deploy script is under `infra/` in the repo. Rollback via `gcloud run services update-traffic --to-revisions=<name>=100`.

Client action: None. Adding a newly authorised developer to the GitHub repo is enough for them to trigger deploys — the workflows do the rest.

---

§3 — Final Repository Verification

Your ask: Repo name(s), production branch, staging/dev branch structure, latest production commit/tag, confirmation deployed code matches repo, no uncommitted production changes on any developer machine, all infra/deploy scripts committed.

Status: Completed.

Delivered in 03-repository-verification/:

- `repo-verification.pdf` — repo names (`physioguidance1-arch/physioguidance` + Strapi if separate), main branch, deployed commit SHA cross-checked against Cloud Run image tag.

Client action: None. Repository is already transferred to the `physioguidance1-arch` org.

---

§4 — Missing / Incomplete Deliverables

4a. Evidence Matrix

Status: Completed.

Delivered in 04-missing-deliverables/evidence-matrix/:

- `nelc-evidence-matrix.csv` — every applicable NELC requirement mapped to control / implementation / feature / evidence location / relevant document / API/DB/audit source / validation status.
- `NELC-EVIDENCE-README.pdf` — how to read the matrix + evidence bundle overview.

4b. Platform Owner Guide

Status: Completed.

Delivered in 04-missing-deliverables/:

- `platform-owner-guide.pdf` — full owner responsibilities across GCP, GitHub, Strapi, domains/DNS, production integrations, billing, IAM/access, backups, monitoring, security, secret management, incident escalation, vendor accounts, ownership transfer. This replaces the earlier budget-only draft.

4c. Design Assets

Status: Delivered (source-link + expected zip of production images).

- **Figma design source:** physioguidance.org FInal — full design file, access via Figma workspace login.
- **Production images/logos/icons zip:** being provided by the client separately as `physioguidance-public-assets.zip` — will be dropped into 04-missing-deliverables/design-assets/ on arrival.
- The exports currently used in production live in `frontend/public/` in the repo (logo.png, nelc-logo.png, payment icons, illustrations).

To also save a local `.fig` for a fully offline handover, open the Figma file → File menu → "Save local copy". Details in 04-missing-deliverables/design-assets/README.md.

4d. Tutorial / Walkthrough Videos

Status: Delivered as Supercut stack link. Local MP4 exports available on-demand from the same UI.

- **Supercut stack (title: Physio):** https://supercut.ai/stack/f6e0c007-f944-4474-887e-85c80cc08005/ZxPN5YsKs3I8BKaEIJ1lAw
- The stack contains all seven walkthroughs (Student journey, Instructor course build, Manager approval, Finance workflow, Payment success, Zoom session, Certificate approval).
- Per-video MP4 download is available directly from the Supercut player UI. Once downloaded, drop the files into 04-missing-deliverables/walkthrough-videos/ so the handover no longer depends on the Supercut share link at all. Suggested filenames in that folder's README.

---

§5 — User Guides

Your ask: Student / Instructor / Course Manager / Admin / Finance / Support guides that match the final production UI, include screenshots where useful, reflect course-lifecycle changes (Active → Ended → Completed → Archived), cancellation/deletion rules, refund override rules, Zoom/Webinar course modules, assessments, certificates + CME, VAT config, Tabby/Tamara production status, gateway enable/disable, updated EN/AR UI.

Status: Completed.

Delivered in 05-user-guides/:

- `student-guide.pdf` — 37 sections; signup with Saudi National ID rules, all four payment methods, learning + assessment player, certificate flow, Points, Rewards, Billing (4 tabs), Privacy (consents + data export + delete with 30-day grace), EN/AR UI.
- `instructor-guide.pdf` — 17 sections; trainer OTP application, three delivery types, course-lifecycle table (what instructor can / cannot trigger), materials workflow with manager review gate,

assessments, certificate approve/reject/hold (revoke is manager-only).

- `course-manager-guide.pdf` — 20 sections; all 13 sidebar sections including Content Review, Assessments, NELC Compliance, Reports (11 report types), batch cert actions.
- `admin-guide.pdf` — 24 sections; all 17 sidebar items, 11 settings sub-tabs, endpoints appendix. Explicitly leads with "Certificates are a MANUAL workflow — NOT auto-issued" (correction from an earlier draft).
- `finance-guide.pdf` — 18 sections; two entry points (standalone Finance shell vs Admin super-view), reconciliation & escalations, coupons/campaigns, 8 report types, VAT per course, admin super-actions.
- `support-guide.pdf` — 19 sections; two sub-roles (agent + supervisor), full loop-in / transfer / merge / escalate flows, macros, KB, team management, 8 report types.

Every capability was verified against controller/UI code before being written. Screenshots from production platform can be added if wanted — say the word.

Client action: None.

---

§6 — Payment Gateway Production Configuration

Your ask: Verify actual deployed config (backend mode, frontend key, CDN env, webhook, callback URL, prod/test toggle, gateway health test, refund config) for Tabby (prod), Tamara (prod), Moyasar (test until live), Bank Transfer (prod/manual). Provide complete self-serve documentation for Moyasar activation.

Status: Completed. Moyasar activation is now fully self-serve from the admin dashboard.

Delivered in 06-payment-gateways/:

- **`moyasar-activation-self-serve.pdf`** — complete step-by-step guide for the platform owner to activate Moyasar production, switch Test → Live, verify, roll back, and rotate credentials **entirely from the admin dashboard**. No gcloud command, no CI redeploy, no developer involvement required.
- Also delivered as code in this cycle: a new **Moyasar Mode dropdown** in admin Settings → System → Payments. The DB-stored mode wins over the `MOYASAR_MODE` env var, so a single UI change flips Test → Live. Details in the self-serve guide.
- Cross-refs: general gateway workflow in 05-user-guides/finance-guide.pdf §5 + §12. Env-var / Secret Manager alternative path in 14-env-config-and-secrets/environment-configuration-CONFIDENTIAL.pdf.

Client action (all owner-side, no developer needed):

1. Upload SCFHS license to Moyasar dashboard.
2. Wait for Moyasar approval (~1–3 business days).
3. Follow the self-serve guide: copy live keys + webhook secret from Moyasar → enter in PhysioGuidance admin → Settings → System → Payments → select "Live" mode → Save → verify

with a 1 SAR test transaction.

That's it. Steps 1–3 can all happen after the developer contract has ended.

---

§7 — NELC Final Handover Evidence

Your ask: Final NELC validation result, CRS001 evidence, production configuration status, tested learner journey evidence, xAPI validation outcome, production LRS confirmation, screenshots from successful validation, evidence matrix.

Status: Completed.

Delivered in 07-nelc-final-evidence/:

- `nelc-compliance.pdf` — full implementation reference: 10 verbs (registered, initialized, watched, completed, progressed, attempted, rated, earned, logged-in, attended), LRS mode toggle (`POST /admin/integrations/nelc/mode` , SUPER_ADMIN only), retry logic with 500ms/1s/2s backoff, per-hour cron with `DistributedLockService` , certificate PDF generation in-process, verification URL pattern.
- `nelc-screenshots/` — screenshots from successful validation (alerts-nelc-audit, audit-logs-evidence, audit-logs, certificates-verification, lrs-connection, nelc-user-journey, public-nelc, user-journey-nelc).
- Cross-ref: evidence matrix in 04-missing-deliverables/evidence-matrix/nelc-evidence-matrix.csv.

Client action: None.

---

§8 — PDPL Technical Completion

Your ask: Complete all in-scope technical PDPL items (user data access/export, account deletion/erasure, portability, consent management + withdrawal + marketing + sensitive-data, retention/purge, refresh-token / OTP / email-verification cleanup, inactive-user handling, anonymisation, audit evidence). Provide a final PDPL table with every control classified.

Status: Completed.

Delivered in 08-pdpl-compliance/:

- `pdpl-compliance.pdf` — Article-by-article implementation reference (Art. 4, 6, 11, 12, 13, 18, 25, 26, 27, 29). Includes the cookie-consent banner (strict opt-in for GTM + GA4 + Meta Pixel) added this cycle.

- `pdpl-controls-matrix.csv` — every control classified in your 4-category vocabulary. Final counts: **23 Implemented / 1 Not Applicable / 6 Requires Client/Legal Action**. Zero "Outstanding Development" — every technical gap has been closed.
- `pdpl-data-classification.csv` — every field classified by sensitivity + legal basis.
- `pdpl-inactive-user-policy.pdf` — draft policy (24-month → warn → 30-day → delete) for your sign-off.
- `privacy-notice-draft/` — Privacy Notice drafts (EN + AR) for legal review + Strapi publishing.

Client action (the 6 Requires Client/Legal Action items):

1. Sign off the inactive-user handling policy.
2. Finalise + publish Privacy Notice content (drafts provided).
3. Finalise + publish Terms of Service content.
4. Nominate the named PDPL Data Controller (name + email + phone).
5. Write internal Data Breach Notification procedure (detection is already automated via Sentry + Cloud Logging).
6. Sign DPAs with Zoom, NELC, Moyasar, Tabby, Tamara, Resend, Google Cloud and file them.

---

§9 — Security Hardening

Your ask: Cloud SQL SSL-only + deletion protection + PITR; per-service SAs (API/worker/CMS/malware/tasks-jobs); confirm Owner/Admin IAM + 2FA + removable dev accounts; verify auth lockout wired to logic; malware-scan gate for sensitive downloads + upload limits; SSH/RDP firewall; WAF review.

Status: Completed.

Delivered in 09-security-hardening/:

- `security-architecture.pdf` — full production security reference. Email-OTP 2FA + trusted device fingerprinting, per-service runtime SAs (api-runtime, worker-runtime, web-runtime, strapi-runtime, malware-runtime, tasks-dispatcher, reconciliation-cron), CSP with nonces, HSTS + all secure headers, argon2 password hashing + wired lockout, encrypted PII fields (`phone` , `nationalId` , `scfhsNumber`), Cloud SQL SSL-only + PITR + deletion protection.
- `wif-setup-for-amna.pdf` — Workload Identity Federation setup (no JSON keys on any developer machine).
- `least-privilege-service-accounts-for-amna.sh` — verifiable script to enumerate current per-service SA bindings.
- `secrets-rotation-plan.pdf` — full rotation plan per secret category; safe-vs-blind-rotate rules for encryption keys.

- `secrets-rotation-log.pdf` — running rotation log (empty entries for post-handover rotations to append).
- `malware-unscanned-file-gate.pdf` — the opt-in `requireCleanScan` gate on `StorageService.getSignedUrl()`: **403 quarantined / 425 pending** for private/trainer buckets. Bank-transfer approval refuses at the service layer if scan not `clean`.

Client action:

- Amna revokes `ghulam@` temporary `cloudsql.admin` grant (was needed for backup drill; no longer required).
- Amna confirms 2FA is enabled on all Owner/Admin IAM identities.

---

§10 — Monitoring & Alerting

Your ask: Backend Sentry actually sending; real `/health/ready` (not stub); production uptime checks; Cloud Run Job failure alerts for critical jobs; dashboards; long-term logging (audit/security/errors/incidents/compliance); alert ownership on client-owned account.

Status: Completed. Alerts route to `nelc.platform@gmail.com` (client-owned).

Delivered in 10-monitoring-alerting/:

- `monitoring-alerting.pdf` — Sentry backend confirmed sending (`@sentry/nestjs` in `instrument.ts`); real `/health/ready` returns 503 on Postgres failure, reports Redis inline; six alert policies (5xx spike, failed-login burst, suspicious 403 burst, malware detected, site-down, job-failure); uptime checks every 60s from 6 regions on `/api/health/ready` and homepage; long-term log retention set to **400 days** on `_Default` and `_Required` log buckets; admin Monitoring dashboard covers 25 background jobs.
- `alert-recipients-status.pdf` — current alert routing; how to modify recipients.

Client action: None. If you want to add a second recipient (e.g. a secondary SRE), instructions in `alert-recipients-status.pdf`.

---

§11 — Disaster Recovery & Backup Hardening

Your ask: PITR enabled; Cloud SQL deletion protection; GCS versioning review; backup verification with restore test + last successful test date; Redis persistence risk documented with queue-recovery mechanism; regional failure procedure.

Status: Completed.

Delivered in 11-disaster-recovery/:

- `regional-failure-playbook.pdf` — accepted risk statement for the me-central2 pinning (SDAIA / PDPL residency mandate), plus the manual regional-recovery procedure.
- `redis-persistence-risk.pdf` — which queues could lose work on Redis restart (payments, xAPI, notifications, support, sessions) and the requeue mechanism for each (payment reconciliation cron, xAPI retry queue, notification retries, etc.).

Cross-refs:

- Cloud SQL PITR + deletion protection + SSL + daily backups verified: see 17-final-production-verification/production-verification-checklist.pdf rows A5, A6, A7, A8.
- Backup drill completed 2026-08-17 (cloned `physioguidance-db-me` → `physioguidance-db-me-drill-20260817`, verified row counts, deleted clone) — evidence row R3 in the verification checklist.

Client action: None.

---

§12 — GCP Infrastructure Cost Optimization

Your ask: Final config (Cloud Run services / Jobs / Scheduler / Tasks), final job frequencies, converted cron→Tasks list, monthly execution estimate, Cloud Run Jobs CPU cost, estimated total monthly GCP cost, explanation for earlier over-billing, confirmation optimisation doesn't break critical functions.

Status: Completed.

Delivered in 12-cost-optimization/:

- `cost-tally.pdf` — final counts: **5 Cloud Run services, 3 Cloud Run Jobs (video transcode, captions, WCAG), 3 Cloud Scheduler jobs, 8 Cloud Tasks queues** (session/ticket/payment/maintenance/points/backup/report/system). Per-service sizing, monthly execution estimates, breakdown of what former polling crons were converted to Cloud Tasks or Cloud Scheduler, estimated total monthly bill.

Client action: None.

---

§13 — Budget Alert

Your ask: Confirm GCP Budget Alert configured, or specify the owner-only steps + recommended monthly budget.

Status: Requires Client Action (owner-only step by design).

Delivered in 13-budget-alert/:

- `budget-alert-status.pdf` — this is an owner-only console action. Full step-by-step procedure with recommended monthly budget threshold based on the final optimised cost.

Client action: Follow the procedure in the PDF. ~5 minutes in the GCP console.

---

§14 — Environment Configuration & Production Secrets

Your ask: All production secrets in Secret Manager; no secret only on dev machine; nothing hard-coded; `.env` not committed; `.env.example` names-only; another authorised developer can deploy using client-owned GCP; credential/access rotation plan; revoke dev access post-handover; safe encryption-key rotation procedure.

Status: Completed.

Delivered in 14-env-config-and-secrets/:

- `environment-configuration-CONFIDENTIAL.pdf` — exact env-var inventory per service (api=44 env + 32 secrets, worker=44 env + 29 secrets, web=2 runtime + 10 build-time + 3 build-secrets, cms=11 env + 6 secrets, malware-scanner=2 env + 0 secrets). Every secret name is listed; **no secret values in this doc**.

Cross-ref: rotation plan is in 09-security-hardening/secrets-rotation-plan.pdf.

Client action:

- Revoke Ghulam's temporary `cloudsql.admin` grant (post-backup-drill cleanup).
- File `MOYASAR_WEBHOOK_SECRET_LIVE` once Moyasar activates (see §6).
- Optional: rotate any secret that had developer visibility during the build phase — see the rotation plan for the safe procedure per secret category.

---

§15 — Third-Party Services Ownership

Your ask: Final table of every third-party service with account owner, login email, environment, status, PhysioGuidance-owned flag, developer-owned dependency flag, rotation procedure, credential storage location.

Status: Completed.

Delivered in 15-third-party-services/:

- `third-party-services-ownership.csv` — Google Cloud, GitHub, Cloud SQL, Redis, Strapi, Zoom, NELC LRS, Moyasar, Tabby, Tamara, Resend, Sentry, reCAPTCHA, OpenAI, DNS Provider, Google Tag Manager, Google Analytics 4, Meta Pixel. Every row shows owner, login email, environment, PhysioGuidance-owned status, developer-dependency status, rotation procedure, credential location.

Note: GTM / GA4 / Meta Pixel are now consent-gated (PDPL). See §8.

Client action: Confirm the "Login/account email" column matches the actual accounts you own. DNS registrar identity to be confirmed at handover.

---

§16 — Documentation Consistency

Your ask: Every document reflects the final production state consistently. Reconcile discrepancies in backend Sentry / payment gateway environments / job scheduling / Cloud Run architecture / NELC environment / monitoring / security controls / backup-DR / anything else changed post-generation.

Status: Completed.

Delivered in 16-documentation-consistency/:

- `system-architecture.pdf` — verified against `infra/config.sh`, `infra/*/deploy.sh`, and every module folder. Corrected: Next.js 16 (not 15), Strapi folder is `strapi/`, exactly 3 Cloud Run Jobs (not 25 fictitious ones), 8 Cloud Tasks queues.
- `gcp-deployment.pdf` — Cloud Run services list, per-service SAs, buckets, secrets — every claim verified against provisioning scripts.
- `api-reference.pdf` — 620 endpoints across 59 controllers, each verified for path, method, role guard, and description. Rate limits reconciled.
- `developer-guide.pdf` — Node version, Postgres port (5433 in local dev), migration path, actual npm scripts, four GitHub workflows.
- `ops-runbook.pdf` — migration flow via `cloud-sql-proxy` + `drizzle-kit migrate`; reconciliation is a Cloud Scheduler job (not a Cloud Run Job); rollback procedure; restore-clone lifecycle.
- `strapi-cms.pdf` — content types (8 collections + 18 singles), i18n locales, GCS upload provider, admin URL.

Every doc references the deployed commit at the top of the cover page so you can verify at a glance.

Client action: None.

---

§17 — Final Production Verification

Your ask: Pass/Fail checklist covering website health, EN/AR, all six role workflows, course lifecycle transitions, cancellation/deletion rules, enrollment, payment success/failure, refund, invoice, VAT, Tabby/Tamara/Moyasar status, Zoom, attendance, assessments, certificates, CME, NELC/xAPI, notifications, malware scan, backups, monitoring, Strapi editing, mobile responsiveness.

Status: Completed. 123 items total, 119 PASS, 3 deliberate deferrals with reason, 1 blocked upstream on Moyasar SCFHS.

Delivered in 17-final-production-verification/:

- `production-verification-checklist.pdf` — every row shows PASS (auto), PASS (manual — verified by Amna 2026-08-17), or Deferred/Blocked with reason. Categories A–T cover infrastructure, public site, student journey, instructor, course manager, admin, finance, support, courses, payment, Zoom, integrations, media, backups, notifications, and security.

The 4 non-PASS items are all documented externally or intentionally deferred with rationale (Cloud Armor per your own §9 scoping; A15 job-failure push alerts and R4 backup-failure push alerts deferred with reason since dashboard visualises them and no failure has occurred; J2 Moyasar activation upstream).

Client action: Read and acknowledge the checklist. Provide any items you want re-verified.

---

§18 — Final Ownership Confirmation

Your ask: Written confirmation of source-code / repo / deploy-script / doc / design-asset / video / production-config / third-party-account transfer + independence from Ghulam's personal machine, GitHub, GCP, or vendor accounts.

Status: Will Complete (draft in progress).

Delivered in 18-ownership-confirmation/:

- `ownership-confirmation.pdf` — the formal signed statement covering every bullet from your §18. Will be finalised once the four remaining external items (design assets, video downloads, Moyasar activation, cloudsql.admin revoke) land.

Item-by-item status at a glance

§	Item	Status
2	CI/CD & Deployment Independence	Completed
3	Final Repository Verification	Completed
4a	Evidence Matrix	Completed
4b	Platform Owner Guide	Completed
4c	Design Assets	Delivered (Figma link + incoming zip)
4d	Tutorial/Walkthrough Videos	Delivered (Supercut stack; per-video MP4 export available)
5	User Guides	Completed
6	Payment Gateway Production Configuration	Completed — Moyasar activation now self-serve from admin
7	NELC Final Handover Evidence	Completed
8	PDPL Technical Completion	Completed; 6 client/legal actions remain
9	Security Hardening	Completed; 2 minor client actions
10	Monitoring & Alerting	Completed
11	Disaster Recovery & Backups	Completed
12	Cost Optimization	Completed
13	Budget Alert	Requires Client Action (owner-only)
14	Environment Config & Secrets	Completed; 2 minor client actions
15	Third-Party Services Ownership	Completed; confirm email column
16	Documentation Consistency	Completed
17	Final Production Verification	Completed (119/123 PASS)
18	Final Ownership Confirmation	Will Complete

The one consolidated Client Action list

Everything Amna needs to do, in order:

1. **[§4c]** (Optional finalisation) When ready, drop `physioguidance-public-assets.zip` into `04-missing-deliverables/design-assets/` and save a local `.fig` from the Figma file for a fully offline copy. Figma link + zip source already documented.
2. **[§6]** Once SCFHS license is issued, follow 06-payment-gateways/moyasar-activation-self-serve.pdf — enter live credentials in admin → Settings → System → Payments, select "Live" mode, save. Fully self-serve, no developer needed.
3. **[§8]** Six PDPL client/legal actions:
   - Sign off the inactive-user policy.
   - Finalise + publish Privacy Notice (draft provided).
   - Finalise + publish Terms of Service.
   - Nominate PDPL Data Controller (name + email + phone).
   - Write internal Data Breach Notification procedure.
   - Sign DPAs with each third-party processor.
4. **[§9 / §14]** Revoke Ghulam's temporary `cloudsql.admin` grant.
5. **[§9]** Confirm 2FA is enabled on all Owner/Admin IAM identities.
6. **[§13]** Configure GCP Budget Alert (owner-only console step).
7. **[§15]** Confirm the "Login/account email" column matches the actual accounts you own; confirm DNS registrar identity.
8. **[§17]** Read and acknowledge the verification checklist.

The one Developer To-Do list before formal sign-off

1. **[§4d]** Export downloadable copies of the Supercut walkthrough videos and add to `04-missing-deliverables/walkthrough-videos/`.
2. **[§18]** Finalise `ownership-confirmation.pdf` once items 1, 2, and 4 from the Client Action list above are resolved.

Every doc in this folder was verified against the actual production code and infrastructure before being written. If any claim contradicts what you see live, please flag it and I will correct.